

FIVE BOUNDARIES BEFORE AN AGENT GOES LIVE.

Give the agent a useful job.
Put a hard limit around the consequences.

- 01 **DATA + IDENTITY**
What can it read, and who can it act as?
- 02 **ACTIONS**
What can it change without you?
- 03 **DESTINATIONS**
Where can your information leave?
- 04 **RUNTIME**
How far can one run go?
- 05 **STOP + RECOVER**
Can you halt it and restore the work?

Use this before connecting real credentials or enabling live writes. Each boundary includes a configuration decision, a safe test, and evidence to keep.

DATA + IDENTITY

What can it read?

Start with a named task and a dedicated identity. Access should follow the job, not everything your own login happens to unlock.

SET THE BOUNDARY

Give it one project folder, a filtered dataset, or a dedicated service account. Prefer read-only scopes. Keep production secrets outside its workspace; use short-lived, narrowly scoped credentials where supported.

WHAT THIS LOOKS LIKE

For a lead-research agent: allow a sample company list and public web research. Keep customer exports, your personal inbox, and billing credentials out of reach.

SAFE TEST / 01

Create a harmless file outside the permitted folder. Try to read it through the same tool the agent uses. Then try a prohibited operation with a test credential. The underlying system should deny access even if the agent asks confidently.

KEEP THIS RECEIPT

Allowed paths and account scopes; credential owner; expiry or revocation method; the denied-access result.

A prompt saying "do not read this" is a preference. A permission that refuses the read is a control.

ACTIONS

What can it change?

Separate preparing work from committing it. Give the agent useful autonomy inside a narrow action set.

SET THE BOUNDARY

List permitted operations explicitly: read, draft, create, update, send, publish, delete, pay. Disable unused tools. Require a separate approval or tightly constrained service for actions with material external consequences.

WHAT THIS LOOKS LIKE

An email assistant can summarize messages and create drafts. Sending to a new recipient, deleting mail, or changing account access should use a separate, enforced path.

SAFE TEST / 02

Use a staging account with no real recipients or money. Ask for an operation outside the allowed set. A tool or permission check must stop it before the side effect. A model refusal alone is not a pass.

KEEP THIS RECEIPT

Operation allowlist; destination and amount limits where relevant; approver; proof that a prohibited action was blocked.

Review the actual recipient, payload, amount, or diff. Approving "continue" without those details is not meaningful review.

DESTINATIONS

Where can data leave?

A browser visit, API request, upload, or message can move information out of your environment. Treat each as a potential exit.

SET THE BOUNDARY

Allow only the network destinations the job needs. Restrict uploads and outbound messages separately. Keep untrusted webpages and documents as task data; do not let them grant new permissions or choose privileged actions.

WHAT THIS LOOKS LIKE

A document summarizer can read an approved folder and save a local summary. It does not need arbitrary web uploads or permission to email the source files elsewhere.

SAFE TEST / 03

In an isolated test environment, use a dummy document that asks the agent to send a synthetic marker to an unapproved destination. Confirm the outbound request is blocked and the marker does not appear in your controlled receiver logs.

KEEP THIS RECEIPT

Approved destinations and operations; dummy marker; block log; receiver result. Never use a real secret for this drill.

A familiar domain can still receive sensitive data through a URL or upload. Check what is being sent as well as where.

RUNTIME

How far can one run go?

Contain the work, then limit its duration and reach. Keep the environment disposable without treating it as invulnerable.

SET THE BOUNDARY

Use an isolated, patched environment with only required mounts and services. Apply filesystem and network restrictions together. Set time, tool-call, and spending limits outside the model, and stop new work when a limit is reached.

WHAT THIS LOOKS LIKE

For a prototype: disposable workspace, staging data, a short timeout, a capped number of tool calls, and no production keys. Choose actual limits from the job and verify how your provider enforces them.

SAFE TEST / 04

Run a harmless repeating task in the test environment. Confirm the timeout or call cap ends it and queued work does not continue. Inspect the environment for unintended host mounts or reachable internal services.

KEEP THIS RECEIPT

Environment version; mounted paths; network policy; configured limits; termination time; queue state after stopping.

Some provider budgets only alert after usage. Do not call a notification threshold a hard spending limit.

STOP + RECOVER

Can you undo the damage?

Before the first live run, name the person who can stop it and the exact control they will use. Then practice recovery.

SET THE BOUNDARY

Keep stop controls outside the agent's authority. Pause the trigger, cancel queued jobs, and revoke credentials if needed. Log actions and errors with sensitive values redacted. Back up state before changing it.

WHAT THIS LOOKS LIKE

For a CRM update: export the affected records first, use a small batch, retain the change log, and verify that you can restore that batch. Do not give the agent permission to disable its own audit trail.

SAFE TEST / 05

Start a staging run, activate the stop control, and verify no new actions execute. Restore a changed test record from the backup. Check that logs show what ran, what stopped, and who intervened.

KEEP THIS RECEIPT

Named owner; stop location; revocation steps; backup reference; restore result; run identifier and redacted action log.

An email already sent or a file already disclosed cannot be recalled reliably. Recovery does not replace prevention.

An agent that drafts customer replies.

Illustrative setup, not a report of a tested deployment. The job: turn selected support requests into draft replies for a human to review.

ONE JOB / FIVE ENFORCED LIMITS

01 DATA + IDENTITY

Read only a selected support queue and approved help articles. Use a dedicated identity; exclude billing and account-reset tools.

02 ACTIONS

Create drafts. No sending, refunds, deletions, or account changes. A human checks the draft and performs the final action.

03 DESTINATIONS

Read the approved help center. Save drafts to the support system. No other uploads, outbound email, or arbitrary destinations.

04 RUNTIME

Begin with 10 synthetic requests and a 15-minute timeout. These are example starting limits, not universal safe values.

05 STOP + RECOVER

Pause the intake trigger and worker; cancel queued drafts. Preserve a redacted run log. Discard the test drafts and restore test state.

Release rule: complete the five denial / recovery drills before replacing synthetic requests with live customer data.

Write the permission design down.

Fill this in, save a copy, and attach the test evidence. If a boundary is unresolved, keep the run in staging or draft-only mode.

ONE SENTENCE JOB

OWNER

REVIEW DATE

01 / ALLOWED DATA + IDENTITY

02 / ALLOWED ACTIONS + APPROVAL POINT

03 / ALLOWED DESTINATIONS + OUTBOUND DATA

04 / RUNTIME + TOOL / SPEND LIMITS

05 / STOP CONTROL + BACKUP / RESTORE EVIDENCE

DRILLS PASSED

☐ Access

☐ Action

☐ Egress

☐ Limits

☐ Restore

A checked box records your test result. It is not a security certification.

Keep the useful layer. Add the missing limits.

A sandbox is a security boundary, but it is not a guarantee. Combine isolation with narrow permissions, controlled destinations, bounded execution, and a recovery path.

WHAT THE REEL COMPRESSES

Trail of Bits reported three escape attempts it counted as successes against its QEMU/KVM setup. Its final chain involved three vulnerabilities that were 0-days at discovery plus one already patched upstream. This is a specific evaluation, not proof that every agent can escape every VM. [1]

HOW TO USE THIS GUIDE

The five-boundary structure, example workflow, worksheet, and drills are an editorial synthesis for founders. The drills are verification steps for your own setup, not a security certification. Use dummy data in staging; use qualified security review for sensitive production systems.

READ THE PRIMARY SOURCES

- 1 [Trail of Bits - VMs won't contain cyber-capable agents](#)
- 2 [OWASP - LLM06:2025 - Excessive Agency](#)
- 3 [Anthropic - Making Claude Code more secure with sandboxing](#)
- 4 [Anthropic - How we contain Claude across products](#)
- 5 [OpenAI - Understanding prompt injections](#)

Source map: 01-02 [2]; 03 [3,5]; 04 [1,3,4]; 05 [1,4].

Version 1.0 - 06 September 2026. Recheck after changing tools, permissions, models, or deployment environment.